BotBounty • BOT Chain Technical Review Response

Addressed to Leon, @Roy4by4, and @Josh_0zh (BOT Chain Ecosystem Team)

Date:	October 16, 2026
Pinned Commit:	`0c47003c2a64a1ed72c7ec2d28628bcbcabc592f` (Branch: `main`)
Bohr Escrow Contract:	`0xB128F2f442554B6517D779788F28F2EB2612164A` (Chain ID: 968)
Live Web App:	https://botbounty-theta.vercel.app/
GitHub Repository:	https://github.com/Blackwrld04/BOTBOUNTY

Executive Summary: All four review items from commit `a8597f6` have been completely resolved, unit-tested, and deployed on Bohr Testnet. The build is ready for verification immediately with live on-chain transaction hashes covering the full lifecycle (funding, submission, payout, rejection, and refund).

1. Status of Review Checklist Items

Item / Finding	Status	Engineering Resolution
1. Frontend Funding & Real Payout Placeholder "0xarc" text & DB-only payouts	RESOLVED	• Replaced all legacy "0xarc" references and direct-transfer instructions in `CreateBountyModal.jsx` with a 1-click Web3 wallet funding flow directly calling `createBounty(...)` with on-chain explorer receipts. • Payout releases in `bounties.js` and `db.js` now trigger real on-chain transfers (`releaseBounty(...)`) and persist the verified 66-character Bohr transaction hash in the audit ledger rather than updating virtual DB balances.
2. Submission Ownership & Session Auth Spoofable wallet/email parameters	RESOLVED	• Stripped spoofable query parameters (`?email=`, `?wallet=`) and headers (`x-user-email`, `x-wallet-address`). Reads return empty (`[]`) to unauthenticated callers; solvers see only their own submissions; admins see all. • Submission edits require authenticated session tokens (`401`) and strict ownership verification (`403` if editing another solver's work). Body spoofing is completely ignored. • Enforced anti-self-solve lockout preventing bounty maintainers from solving their own bounties. Added 12 automated negative tests (48/48 backend tests passing).
3. Privacy & Blind Submissions Public PR URLs in storage/events	RESOLVED	• Clarified privacy wording across UI and documentation: portal deliverables are confidential between solver and maintainer during review to prevent competitor sniping, while final settlement details and recipient addresses are public on-chain for DAO auditability. • Implemented cryptographic blind commit-reveal escrow in `BotBountyEscrow.sol` (`submitSolutionCommitment` / `releaseBountyWithProof`) with `keccak256(solver, prUrl, salt)` so deliverable URLs are never published on-chain during review.
4. Supported Tokens & Policies Token validation, timeout & rejection	RESOLVED	• Formally configured native $BOT (`address(0)`) and Bridged USDT (`0x75edC9335175Fc0552D51D48439F229c10420fe3`). • Added `settlementToken.code.length > 0` check to reject invalid/EOA token addresses. • Protected against fee-on-transfer discrepancies via balance delta checks (`balanceAfter - balanceBefore == amount`). • Added anti-junk URL guard (`length >= 10`), 1–30 day maintainer review period, rejection with on-chain feedback reasons, timeout auto-claim, and maintainer deadline refund.

2. End-to-End Bohr Testnet Transaction Evidence

> **Separation of Real On-Chain vs. Simulated Paths:** All 8 transactions in the table below were executed live on Bohr Testnet (Chain ID 968) with verified state transitions and balance transfers. The Review Timeout Claim flow enforces an on-chain lock (`MIN_REVIEW_PERIOD = 1 days`) to protect maintainers against instant timeout griefing; therefore, its full lifecycle is verified deterministically in the automated Foundry test suite using `vm.warp(block.timestamp + 8 days)` .

Lifecycle Path	Function Called	Transaction Hash & Bohr Explorer Link	Status
Escrow Deployment	`constructor()`	`0x6b40a134cdb7b0ec20e8aaa9391ff9481f3d5d59f37c76d09e6c8fb36e6cc14f`	SUCCESS
Bounty 1: Funding	`createBounty` (0.01 tBOT)	`0xcd6897b537b4d03db87a0202bd1d41fb3eb545a97076619ef08fd744787fc78c`	SUCCESS
Bounty 1: Submit Work	`submitSolution`	`0x1685b4bdda7e94fd20c0cec6383b532831f5371d090d7f376eba364c68d6ad71`	SUCCESS
Bounty 1: Release & Payout	`releaseBounty` (Solver Paid)	`0xc9c86fa10c4006cc5e76464785064e2d008bd6bc3d42953570b83f3c28a42dd7`	SUCCESS (PAID)
Bounty 2: Funding	`createBounty` (0.005 tBOT)	`0x03db374933374810f03d770ac1126a4d1cd51770fc6b73d6ac01d5ab3f517ff1`	SUCCESS
Bounty 2: Submit Work	`submitSolution`	`0xfea4c93518b4e531a67285a404a9aa8b86ad967eb83405b2fd46f474d7a8c5ca`	SUCCESS
Bounty 2: Rejection	`rejectSolution` (with Reason)	`0x3a8d6b186c11e2aa0a756fff89e63b0bd3c5db5245d48817f7cd0fe2de29586b`	SUCCESS (REOPENED)
Bounty 3: Funding	`createBounty` (0.005 tBOT)	`0x293b85b92c5eb3f8f461db2a1947bc1ba18690e84d4b6e420e8dec836fc2603c`	SUCCESS
Bounty 3: Expire & Refund	`refundBounty`	`0xecc602c5384512aa0f932628bdf0a7fe2d8e4627fd9cf9057638c82040e890c2`	SUCCESS (REFUNDED)
Timeout Auto-Claim	`claimTimeoutRelease`	Simulated via Foundry test suite (`testReviewTimeoutClaim` with `vm.warp`)	Passing Test

3. Automated Test Verification Summary

Smart Contracts (Foundry): 21/21 Passed

- `testNativeBotBountyFlow` : Full deposit & payout
- `testUSDTBountyFlowWithApproval` : ERC-20 flow
- `testRevertOnFeeOnTransferTokenActualAmountMismatch`
- `testRevertOnInvalidTokenAddressNoCode`
- `testRevertOnJunkOrEmptySubmission`
- `testRevertOnMaintainerSolvingOwnBounty`
- `testBlindCommitmentAndReleaseWithProof`
- `testReviewTimeoutClaim` & `testMaintainerRefundAfterDeadline`

Backend & Security (Node.js): 48/48 Passed

- Unauthenticated requests receive empty submission list
- Query/Header spoofing (`?email=` , headers) strictly blocked
- Solver A sees only their own work; Solver B cannot see Solver A
- Unauthorized submission modification blocked (`401/403`)
- Body payload identity spoofing ignored
- Junk URL submissions (<10 chars) rejected (`400`)
- Maintainer self-solve prevention enforced (`403`)
- On-chain settlement transaction hash recorded in audit ledger

4. Next Steps & Mainnet Deployment Gas Request

With all technical items verified, contract deployed on Bohr, and end-to-end evidence established, the build is ready for verification by @Roy4by4 and @Josh_0zh.

We welcome any further review questions and look forward to coordinating the remaining technical milestones, deployment-gas support, and scheduling the limited mainnet pilot.